Merge Status Code

PROM06 TC13 – Over-privileged built-in role assignment (INDEPENDENT) #82

Open abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc13`

Conversation 9 Commits 1 Checks 1 Files changed 2 +26

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant





abdulwaheed384 commented 3 hours ago Owner

PROM06 additional test case TC13 (Over-privileged built-in role assignment), run under the INDEPENDENT workflow (post-PR #69). Ground truth was committed before the fixture: evidence/prom06/ground-truth/TC13-TC15_Ground_Truth.md on branch prom06-evidence. Research fixture only: do not merge, do not apply.

🤖 Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

PROM06 TC13: reporting identity role assignment ··· Unverified ✓ 1e87e00

github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Reporting identity assigned Contributor at subscription scope instead of Reader at resource group scope**
  - Category rationale: The Terraform code assigns the 'Contributor' role at subscription scope to the reporting identity, while the co-located requirements file in the same PR explicitly documents that only 'Reader' access scoped to the research resource group is needed and that write access is not required. The gap between the configured permission and the documented least-privilege requirement is directly evidenced in the changed files and constitutes a concrete over-privileged identity assignment.
  - Evidence: azurerm_role_assignment.tc13_reporting: scope = data.azurerm_subscription.tc13_current.id (subscription scope), role_definition_name = 'Contributor'. Contrasted with tc13_requirements.tf locals: tc13_required_role = 'Reader', tc13_required_scope = 'Research resource group (azurerm_resource_group.rg)', tc13_write_access_required = false.
  - Analysis: The managed identity 'id-prom06-tc13-reporting' is granted the 'Contributor' role at subscription scope via azurerm_role_assignment.tc13_reporting. The Contributor role permits creating, modifying, and deleting most Azure resources across the entire subscription. The tc13_requirements.tf file in the same PR explicitly documents that the reporting task requires only 'Reader' access scoped to the research resource group (azurerm_resource_group.rg), and that write access is not required (tc13_write_access_required = false). The configured role and scope directly contradict the documented least-privilege requirement.
  - Impact: The reporting identity holds write and management permissions across all resources in the subscription, not just the research resource group. If the identity or the service using it is compromised, an attacker could create, modify, or delete arbitrary Azure resources subscription-wide, including network controls, storage, and other managed identities. This far exceeds the stated operational need.
  - Recommendation: Change the role_definition_name to 'Reader' and set the scope to azurerm_resource_group.rg.id to align with the documented requirement. Example: scope = azurerm_resource_group.rg.id, role_definition_name = 'Reader'. This satisfies the reporting task and enforces least-privilege as stated in tc13_requirements.tf.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Managed identity granted Contributor at subscription scope instead of Reader at resource group scope**
  - Category rationale: The role assignment grants the Contributor role at subscription scope, while the requirements file in the same PR explicitly documents that the task requires only Reader access scoped to the research resource group. Contributor at subscription scope allows write, delete, and management operations across all resources in the subscription, far exceeding what is necessary. This is a demonstrated over-privilege weakness supported directly by the supplied code.
  - Evidence: terraform/tc13_reporting_identity.tf — resource "azurerm_role_assignment" "tc13_reporting": scope = data.azurerm_subscription.tc13_current.id, role_definition_name = "Contributor". terraform/tc13_requirements.tf — locals: tc13_required_role = "Reader", tc13_required_scope = "Research resource group (azurerm_resource_group.rg)", tc13_write_access_required = false.
  - Analysis: azurerm_role_assignment.tc13_reporting assigns the built-in 'Contributor' role to the tc13_reporting User Assigned Managed Identity with scope set to the full subscription (data.azurerm_subscription.tc13_current.id). The tc13_requirements.tf file in the same PR documents that the reporting task is 'Read resource information in the research resource group for weekly reporting', that tc13_required_role = "Reader", tc13_required_scope = "Research resource group (azurerm_resource_group.rg)", and tc13_write_access_required = false. The actual assignment violates all three of these constraints: it uses Contributor (not Reader), it targets the subscription (not the resource group), and it provides write access that is explicitly documented as not required. The Contributor role permits creating, modifying, and deleting resources and role assignments across every resource in the subscription, which constitutes a significant privilege escalation vector if the identity is ever compromised or misused.

- Impact: An identity with Contributor at subscription scope can create, modify, or delete any Azure resource in the subscription, exfiltrate data, escalate privileges to other resources, and undermine isolation between research workloads. If the identity's credentials are compromised or the reporting service is exploited, an attacker gains broad write control over the entire subscription rather than read-only visibility into a single resource group.
- Recommendation: Restrict the role assignment to match the documented requirements: set role_definition_name = "Reader" and scope = azurerm_resource_group.rg.id. This confines the identity to read-only access on the research resource group, satisfying the least-privilege principle and aligning with tc13_requirements.tf. Example: scope = azurerm_resource_group.rg.id, role_definition_name = "Reader".

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.





github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.





github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Managed identity granted Contributor at subscription scope; requirements specify Reader at resource-group scope**
  - Category rationale: The Terraform code directly demonstrates that the managed identity is granted Contributor (write/delete) access at subscription scope, while tc13_requirements.tf explicitly states that the task requires only Reader access scoped to the research resource group. The misconfiguration violates least-privilege and is evidenced entirely within the changed files without requiring external context.
  - Evidence: azurerm_role_assignment.tc13_reporting: role_definition_name = "Contributor", scope = data.azurerm_subscription.tc13_current.id. tc13_requirements.tf locals: tc13_required_role = "Reader", tc13_required_scope = "Research resource group (azurerm_resource_group.rg)", tc13_write_access_required = false.
  - Analysis: azurerm_role_assignment.tc13_reporting assigns the Contributor built-in role to the tc13_reporting managed identity with scope set to data.azurerm_subscription.tc13_current.id (the entire subscription). The tc13_requirements.tf file in the same PR explicitly documents that the required role is Reader, the required scope is the research resource group, and that write access is not required (tc13_write_access_required = false). Contributor grants create, update, and delete permissions across every resource type in the subscription, far exceeding what the documented task (read resource information for weekly reporting) requires.
  - Impact: The identity can create, modify, or delete any resource across the entire subscription, including network controls, IAM assignments, storage accounts, and compute. If the identity or its credential is compromised, an attacker gains full write control over all subscription resources, not just the research resource group. This also bypasses the resource-group-level blast-radius boundary implied by the documented scope requirement.
  - Recommendation: Change role_definition_name to "Reader" and change scope to azurerm_resource_group.rg.id to match the documented requirements. Example: scope = azurerm_resource_group.rg.id, role_definition_name = "Reader". This constrains the identity to read-only access on the single resource group, consistent with tc13_required_role, tc13_required_scope, and tc13_write_access_required = false.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.

abdulwaheed384 added a commit that referenced this pull request 3 hours ago

`PROM06: AI quality scoring sheets; TC13–TC15 scans and PR comments` Unverified `ef17f33`

...

All checks have passed
2 successful checks

No conflicts with base branch
Merging can be performed automatically.

Merge pull request

You can also merge this with the command line. View command line instructions.

Still in progress? Convert to draft